Jesús Repiso Rio
3ºA Ingeniería del Software

Práctica 6: Análisis de protocolos

Seguridad en Servicios y Aplicaciones

EJERCICIO 1: El protocolo TELNET y FTP

Se proporcionan dos capturas de tráfico entre un cliente y un servidor, una de tráfico TELNET y otra de tráfico FTP. Se pide responder a las siguientes preguntas para cada uno de los protocolos.

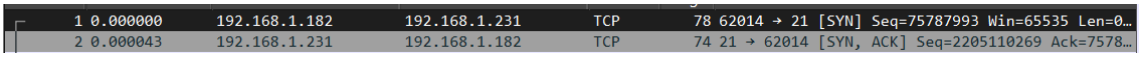
1. ¿Cuál es la dirección IP del cliente y cuál es la del servidor? ¿Cómo has deducido esto?

FTP:

IP Cliente: 192.168.1.182

IP Servidor: 192.168.1.231

Se observa al inicio de la conexión, el cliente envía el SYN para conectarse y el servidor le responde con el SYN y el ACK de confirmación.

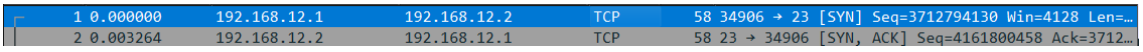


TELNET:

IP Cliente: 192.168.12.1

IP Servidor: 192.168.12.2

Se observa al inicio de la conexión, el cliente envía el SYN para conectarse y el servidor le responde con el SYN y el ACK de confirmación.

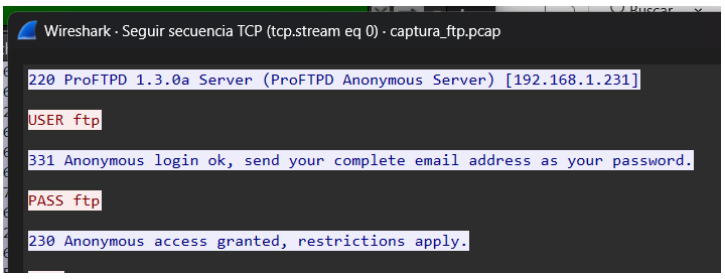


2. ¿Qué credenciales se han utilizado para acceder al servidor?

FTP:

Usuario y contraseña → ftp

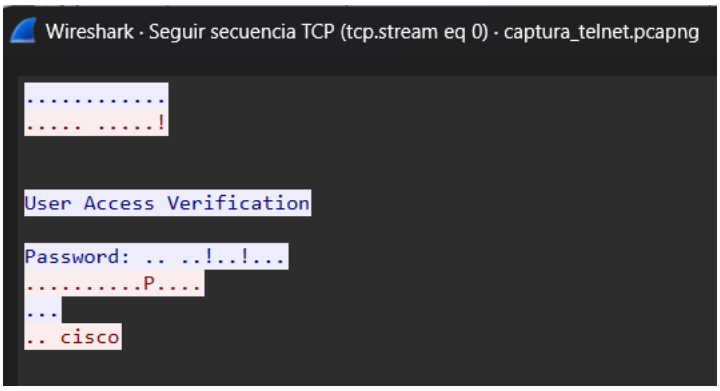
Siguiendo el flujo de los mensajes se observa.



Jesús Repiso Rio
3ºA Ingeniería del Software

TELNET:

Contraseña: cisco

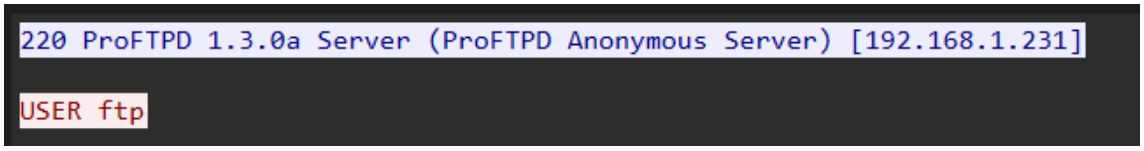


Siguiendo el flujo de los Mensajes observamos esta Salida, que limpiando los puntos (caracteres no imprimibles), los saltos de línea y la P sobrante nos queda la contraseña limpia.

3. ¿Qué tipo de sistema es el servidor?

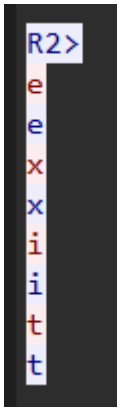
FTP:

ProFTPD 1.3.0a sobre Unix/Linux



TELNET:

Es un router/switch Cisco que ejecuta IOS (prompt R2>).



4. ¿Qué comando(s) ha ejecutado el cliente en el servidor?

FTP:

- USER ftp
- PASS ftp
- SYST

Jesús Repiso Rio
3ºA Ingeniería del Software

- FEAT
- PWD
- EPSV
- LIST
- TYPE I
- SIZE resume.doc
- EPSV
- RETR resume.doc
- MDTM resume.doc
- CWD uploads
- EPSV
- STOR README
- MKD testdir
- MKD testerdir
- RMD testerdir
- CWD ..
- PWD
- TYPE A
- SITE CHMOD 777 resume.doc
- QUIT

TELNET:

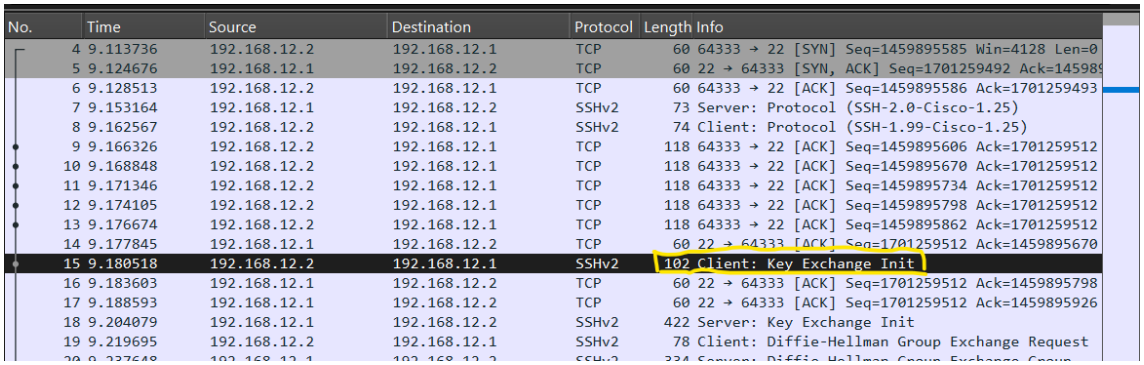
- Exit

EJERCICIO 2: SSH

A continuación, se proporciona una captura de tráfico entre un cliente y un servidor utilizando el protocolo SSH. Se pide responder a las siguientes preguntas.

1. ¿A partir de qué paquete comienzan a establecerse o negociarse las claves de sesión SSH? ¿De qué tipo son las claves de sesión?

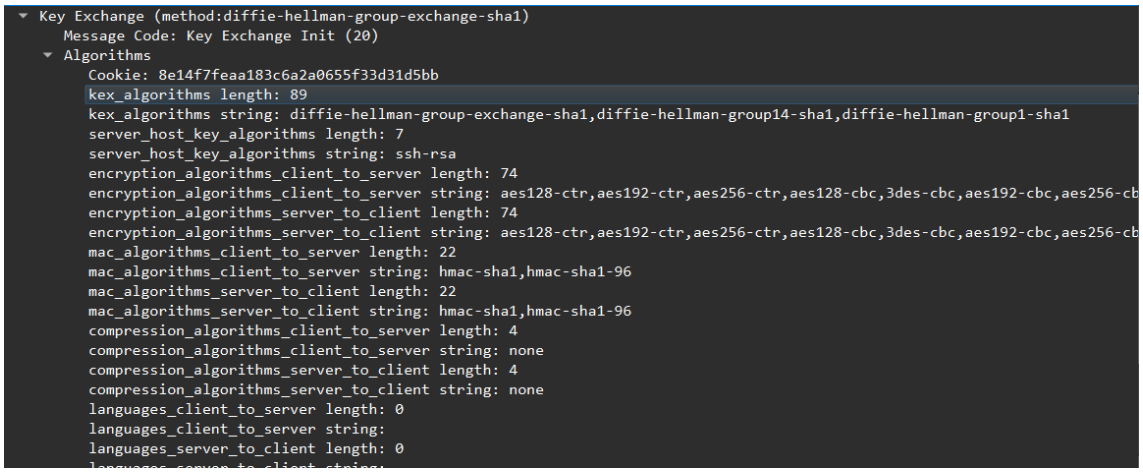
A partir del paquete 15.



No.	Time	Source	Destination	Protocol	Length	Info
4	9.113736	192.168.12.2	192.168.12.1	TCP	60	64333 → 22 [SYN] Seq=1459895585 Win=4128 Len=0
5	9.124676	192.168.12.1	192.168.12.2	TCP	60	22 → 64333 [SYN, ACK] Seq=1701259492 Ack=145989
6	9.128513	192.168.12.2	192.168.12.1	TCP	60	64333 → 22 [ACK] Seq=1459895586 Ack=1701259493
7	9.153164	192.168.12.1	192.168.12.2	SSHv2	73	Server: Protocol (SSH-2.0-Cisco-1.25)
8	9.162567	192.168.12.2	192.168.12.1	SSHv2	74	Client: Protocol (SSH-1.99-Cisco-1.25)
9	9.166326	192.168.12.2	192.168.12.1	TCP	118	64333 → 22 [ACK] Seq=1459895606 Ack=1701259512
10	9.168848	192.168.12.2	192.168.12.1	TCP	118	64333 → 22 [ACK] Seq=1459895670 Ack=1701259512
11	9.171346	192.168.12.2	192.168.12.1	TCP	118	64333 → 22 [ACK] Seq=1459895734 Ack=1701259512
12	9.174105	192.168.12.2	192.168.12.1	TCP	118	64333 → 22 [ACK] Seq=1459895798 Ack=1701259512
13	9.176674	192.168.12.2	192.168.12.1	TCP	118	64333 → 22 [ACK] Seq=1459895862 Ack=1701259512
14	9.177845	192.168.12.1	192.168.12.2	TCP	60	22 → 64333 [ACK] Seq=1701259512 Ack=1459895670
15	9.180518	192.168.12.2	192.168.12.1	SSHv2	102	Client: Key Exchange Init
16	9.183603	192.168.12.1	192.168.12.2	TCP	60	22 → 64333 [ACK] Seq=1701259512 Ack=1459895798
17	9.188593	192.168.12.1	192.168.12.2	TCP	60	22 → 64333 [ACK] Seq=1701259512 Ack=1459895926
18	9.204079	192.168.12.1	192.168.12.2	SSHv2	422	Server: Key Exchange Init
19	9.219695	192.168.12.2	192.168.12.1	SSHv2	78	Client: Diffie-Hellman Group Exchange Request

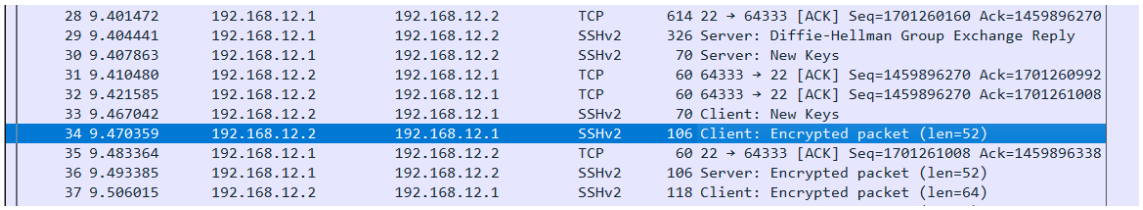
Jesús Repiso Rio
3ºA Ingeniería del Software

Las claves son RSA, y se utiliza Diffie-Hellman para el intercambio.



2. ¿A partir de qué paquete comienza a cifrarse el tráfico de red?

A partir del 34



3. ¿Qué tipo de algoritmos criptográficos se están aplicando para proteger los canales de comunicación?

- Algoritmo de cifrado simétrico: AES (Advanced Encryption Standard) en modo CTR (Counter).
    - Este algoritmo cifra los datos para mantener la confidencialidad, evitando que alguien que intercepte el canal pueda leer el contenido.
- Algoritmo MAC (Message Authentication Code): HMAC con SHA-1.
    - Este algoritmo genera un código de autenticación para asegurar la integridad de los datos y autenticar que el mensaje no fue alterado durante la transmisión.

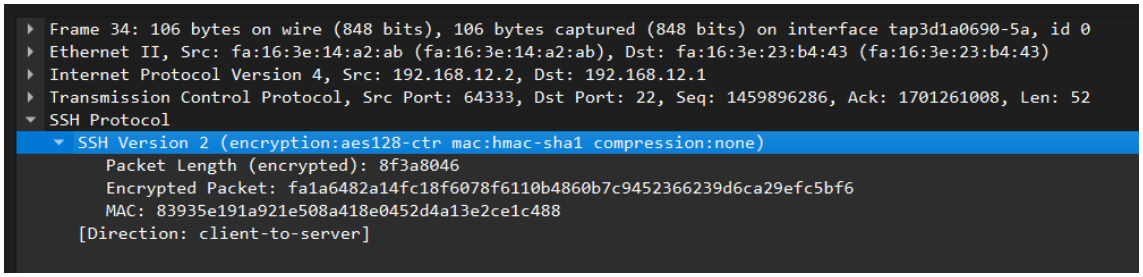
¿Qué parámetros concretos están utilizando esos algoritmos criptográficos?

- Cifrado: AES con clave de 128 bits en modo CTR (Counter).
    - AES-128-CTR significa que la clave es de 128 bits (clave simétrica) y el modo CTR convierte el bloque en un flujo cifrado, permitiendo cifrar datos de tamaño arbitrario.
- MAC: HMAC-SHA1.
    - HMAC usa SHA-1 como función hash para calcular un código de autenticación basado en una clave secreta.

Jesús Repiso Rio
3ºA Ingeniería del Software

¿Se aplica alguna medida de compresión?

No, la compresión está deshabilitada (compression:none). Esto puede deberse a evitar ciertos ataques contra protocolos con compresión o porque la eficiencia/latencia sea prioritaria.



4. ¿Qué tipo de error se está produciendo durante la transferencia de paquetes SSH entre el cliente y el servidor? ¿Quién lo está notificando?

No observo ningún error.

5. ¿Se puede ver la información sobre el usuario y la contraseña?

No, todo va cifrado después del key Exchange.

¿Se puede saber si se está utilizando autenticación basada en contraseña?

Solo indirectamente, viendo en el mensaje de fallo (SSH2_MSG_USERAUTH_FAILURE) que el servidor ofrece “password” como método; pero de nuevo, ese mensaje va dentro del túnel cifrado y precisas las claves para descifrarlo. Pero en esta trama no se observa nada del estilo, por lo que no podemos saberlo.

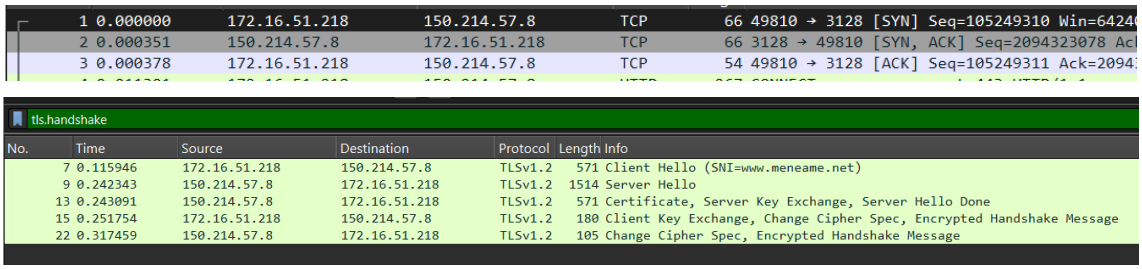
EJERCICIO 3: TLS

A continuación, se proporcionan dos capturas de tráfico TLS, cada una con una conexión. Responder a las siguientes preguntas sobre ambas capturas.

1. ¿Qué tramas pertenecen al handshake y qué tramas a la conexión?

tls_1:

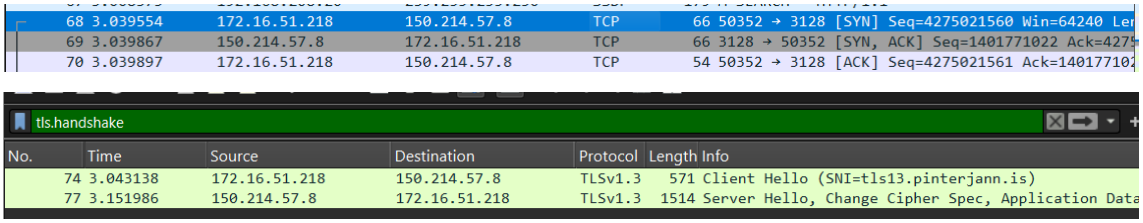
1,2 y 3 para TCP y para TLS las tramas 7, 9, 13, 15 y 22



Jesús Repiso Rio
3ºA Ingeniería del Software

tls_2:

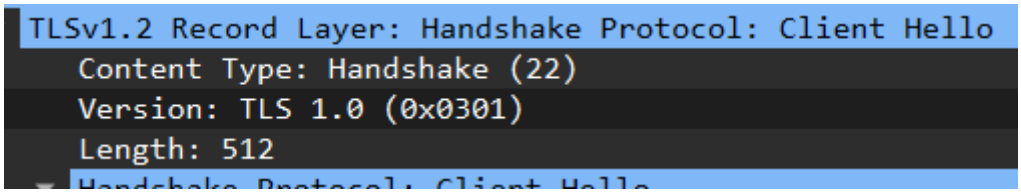
68, 69 y 70 para TCP y para TLS las tramas 74 y 77

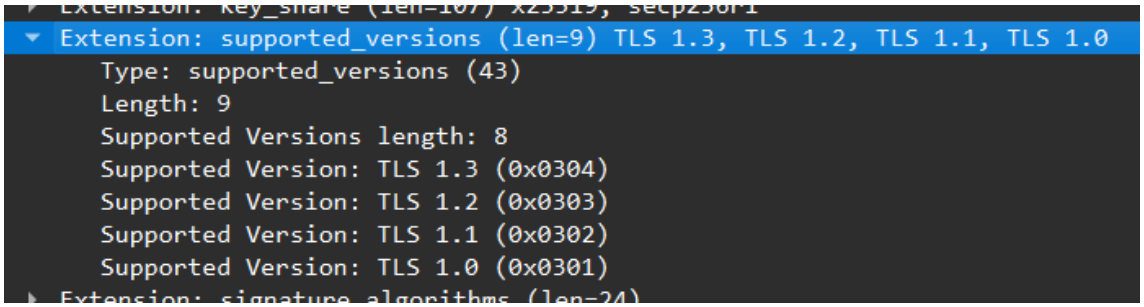


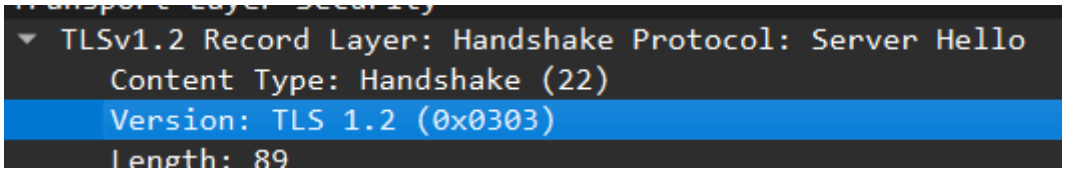
2. ¿Qué versión de Record Layer se utiliza en el Client Hello? ¿Y en el Server Hello? ¿Por qué?

tls_1 y tls_2 (En ambos es igual):

En el Client Hello se usa la TLSv1.0 y en el Server Hello la TLSv1.2. Porque La versión real de la conexión se acordará en el Server Hello, que elegirá una de las versiones ofrecidas en supported_versions.

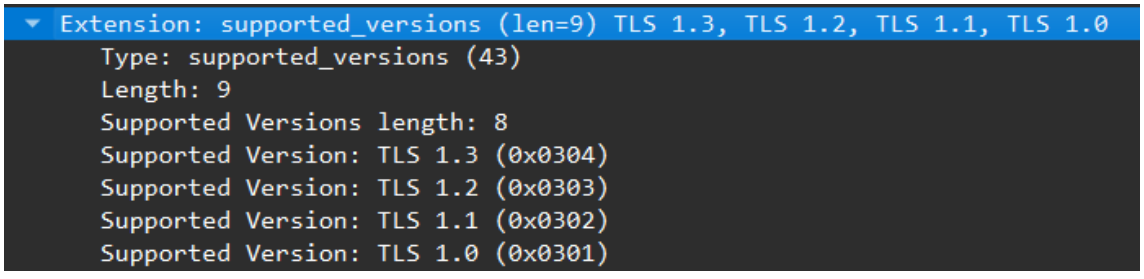






3. ¿Qué versiones de TLS soporta el cliente?

En tls_1 y en tls_2 el cliente soporta las mismas:



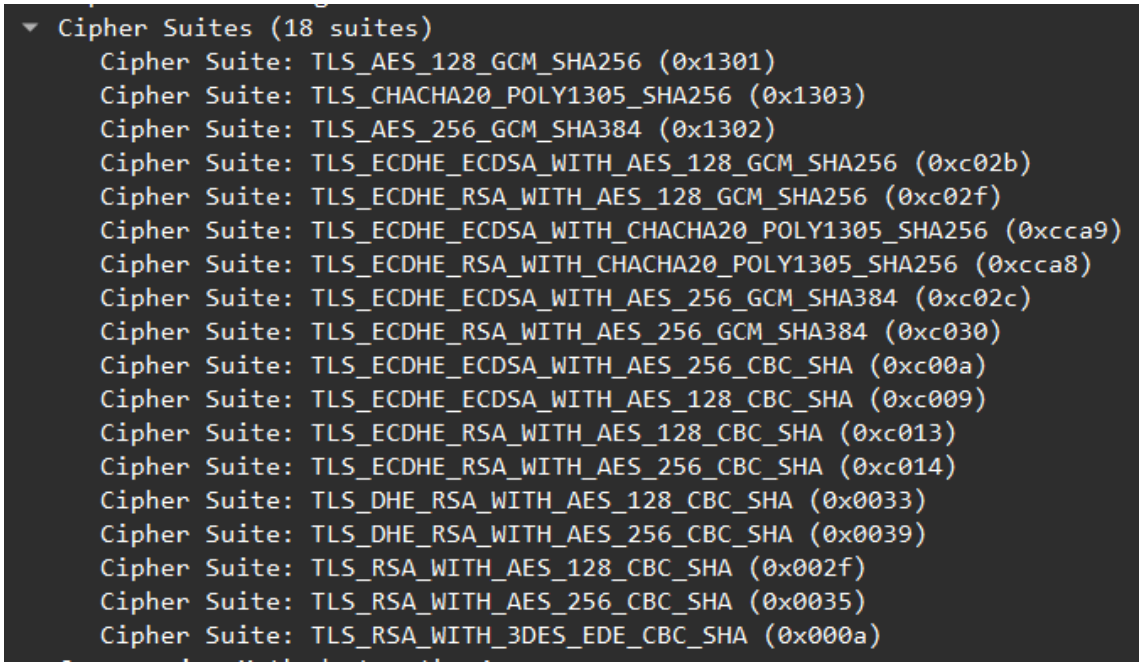
Jesús Repiso Rio
3ºA Ingeniería del Software

4. ¿Qué versión de TLS se utiliza finalmente y dónde se indica? ¿Quién toma la decisión final? CUIDADO: analizar en el paquete TLS, no quedarse directamente con la información proporcionada por wireshark.

Se utiliza la TLSv1.2, que se indica en el Server Hello, ya que es el servidor quien toma la decisión.

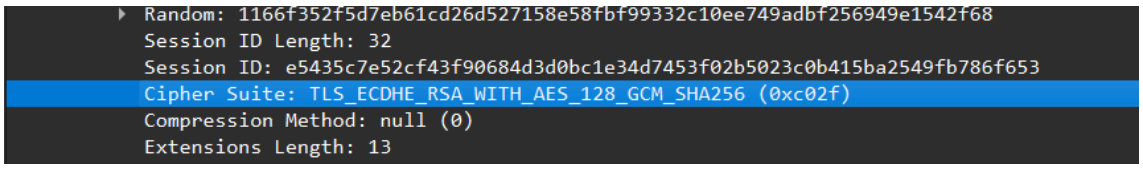
5. En el cliente, ¿dónde salen las suites de cifrado soportadas? ¿Cuáles son?

En el Client Hello (Son las mismas para tls_1 que para tls_2):

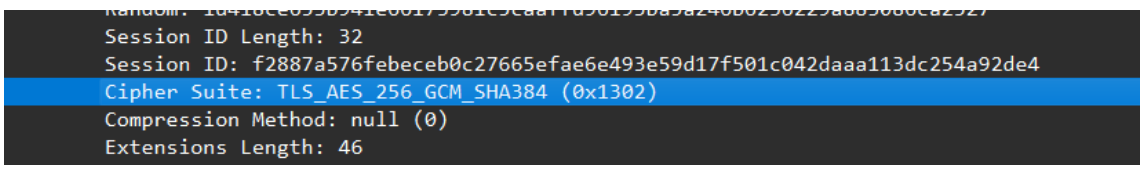


6. ¿Qué suite de cifrado se acepta en la conexión?

Lo observamos en el Server Hello (tls_1):



Sin embargo, en el tls_2 se acepta otra distinta a la del tls_1:



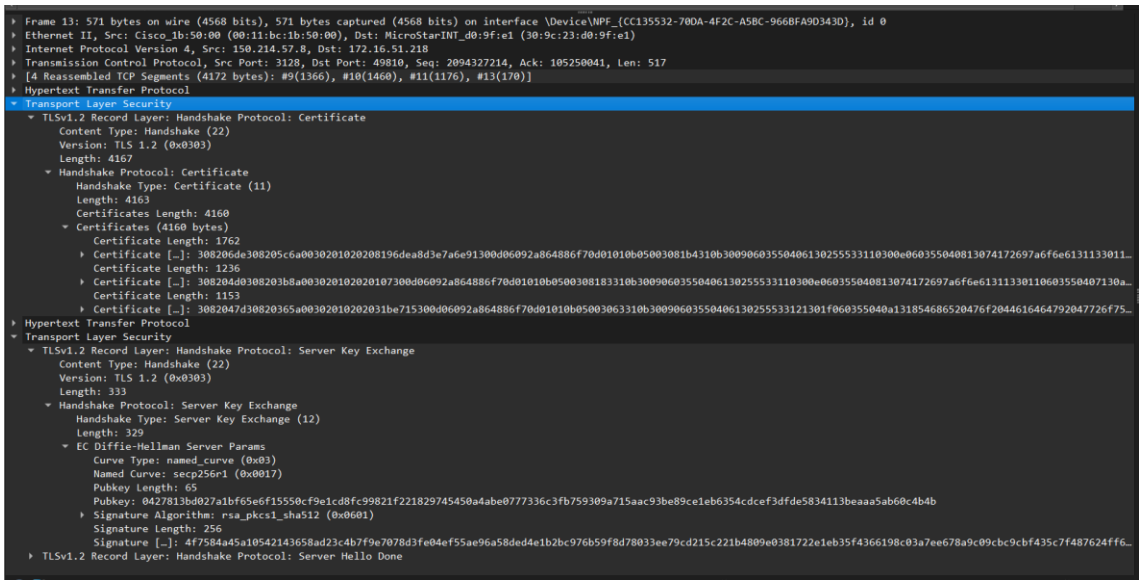
Jesús Repiso Rio
3ºA Ingeniería del Software

7. ¿En qué trama se envía el certificado digital del servidor? ¿Cuál es la clave pública del certificado? ¿Es la misma clave pública que la empleada en el Key Exchange? ¿Por qué?

tls_1:

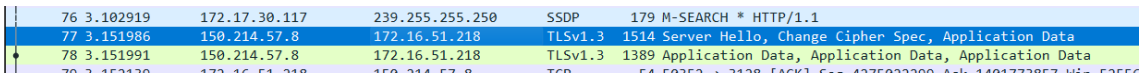
En la trama 13. No es la misma porque el certificado contiene una clave pública RSA usada solo para verificar la firma del servidor, mientras que el intercambio de claves usa una clave efímera ECDHE generada para esa sesión, lo que permite confidencialidad con forward secrecy.

La clave pública del Key Exchange es esta:
0427813bd027a1bf65e6f15550cf9e1cd8fc99821f221829745450a4abe0777336c3fb7593
09a715aac93be89ce1eb6354cdcef3dfde5834113beaaa5ab60c4b4b



tls_2:

Aquí la trama clave es la 77, en esta versión el certificado va en el application data, que, de nuevo, no se puede ver, pero no es la misma que en la del key Exchange porque se utilizan claves elípticas instantáneas.



8. ¿El servidor se autentica al cliente? ¿Y el cliente al servidor? ¿Cómo podemos saberlo?

El servidor sí que autentica, pero el cliente no, por lo que no es mutuo. Lo sabemos porque el servidor siempre envía un certificado, mientras que el cliente no.

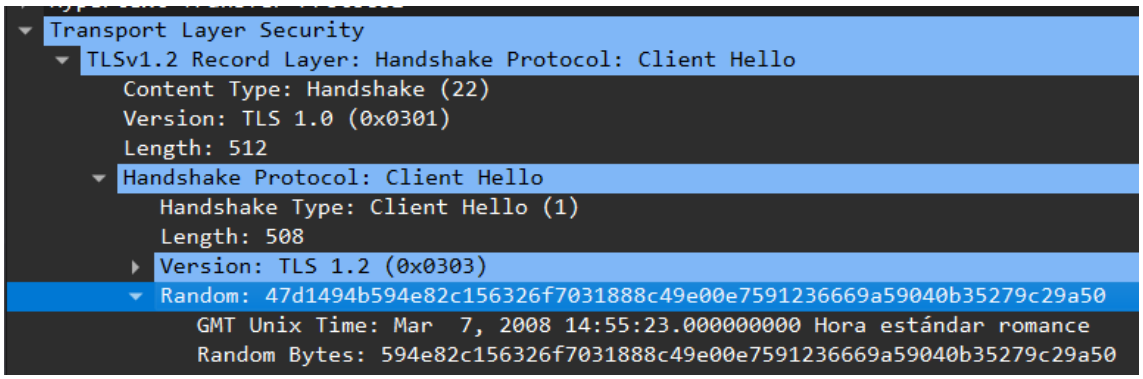
Jesús Repiso Rio
3ºA Ingeniería del Software

9. ¿Cuál es el nonce del servidor? ¿Y el del cliente?

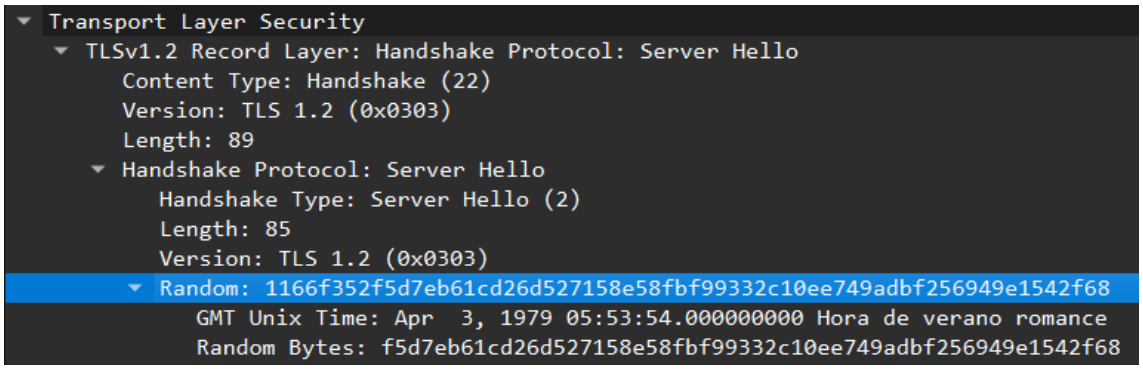
Identificado con el campo Random.

tls_1:

Cliente:

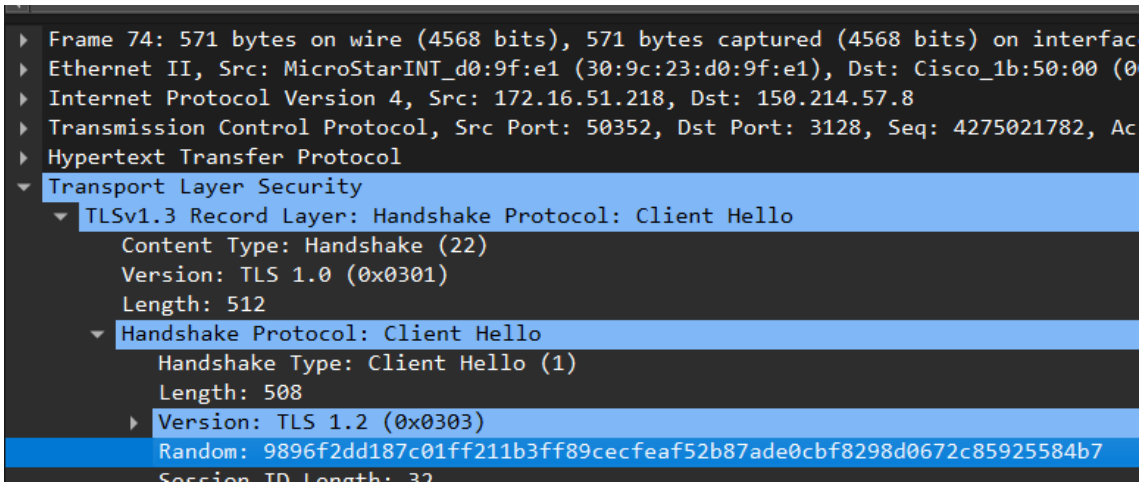


Servidor:



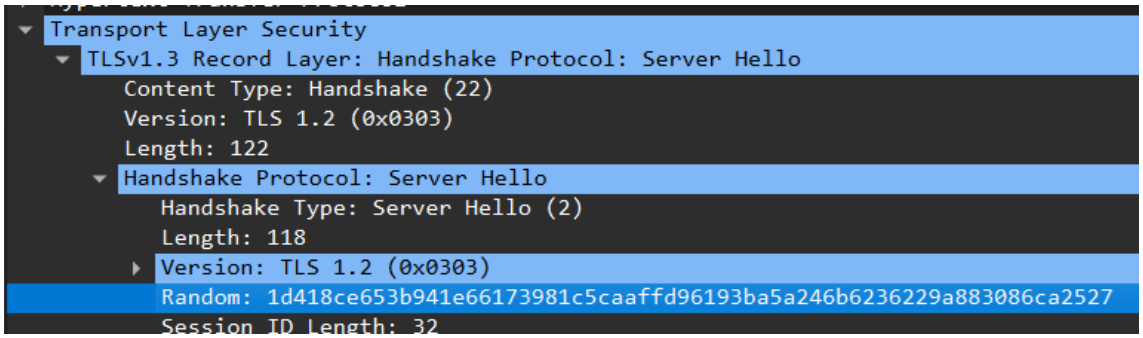
tls_2:

Cliente:



Jesús Repiso Rio
3ºA Ingeniería del Software

Servidor:



10. ¿Puede una misma trama de tipo Record Layer encapsular más de un mensaje de las subcapas superiores a la vez?

Sí, hay una trama en cada captura en la que aparecen varios mensajes en una sola trama.

¿Puede un paquete TCP encapsular más de una trama de tipo Record Layer a la vez?

Sí, TCP es un protocolo de flujo (stream) y puede agrupar múltiples registros TLS en un único segmento TCP